

Admin and Settings

Feature Overview

Field	Value
Feature name	Admin and Settings
Status	Phase 2 complete; extended through Builds 12, 20, 29 and 31
Phase	Phase 2, plus client architecture phases
Priority	Medium

Description

Two related areas: a per-user Settings screen, and a full Admin console for privileged users. Settings gives users control over their profile, storage view, data export and account deletion. The Admin console is a dedicated full-screen workspace (a left sidebar with Dashboard, Users, Admin Management, Audit and Backups) that lets a privileged user review platform-wide metrics, manage accounts, adjust storage limits, unlock, suspend or reinstate accounts, send password reset links, manage other admins, and review the activity (audit) log. In Phase 3 this may integrate with GoodBarber authentication if applicable.

Settings (per user)

User Profile

- ☒ Display user profile (name, email)
- ☒ Edit name
- ☐ In-app change password with current-password confirmation (not built; password changes go through the email reset flow instead - see below)

Storage

- ☒ Display storage usage (amount used against the user's limit)
- ☐ Clear local cache (not built; offline caching is a later-phase goal)
- ☐ Last sync timestamp (not built; depends on offline sync)

Privacy and Account

- ☒ Download my data (CCPA/CPRA style export of account, folders and documents). Build 13: the export is now a human-readable, branded HTML report (was raw JSON), and each document has a Download link that streams through the app's own domain via `/api/files/[id]` rather than exposing the storage host.
- ☒ Delete my account (password-confirmed; deletes all stored files and every related record)
- ☒ Admin panel entry (shown only to admin users)

Security note

- The Settings security note states that documents are stored securely with per-user isolation and time-limited signed access. Build 13 simplified the wording to “Your documents are private and stored securely. Only you can view them.” (the “US-based infrastructure” phrase was dropped from the UI copy). It does not claim encryption at rest, which is deferred as an accepted risk (see `production.md`).

Auto-lock (Build 31)

- Settings has an Auto-lock chooser: the vault locks itself after a period of inactivity and re-locks whenever the app is sent to the background and reopened. This matters because the app runs inside the GoodBarber mobile shell where a phone can be put down mid-session.
- The timeout is a per-user setting with choices of 1, 3, 5 or 10 minutes, or Never, defaulting to 5 minutes. Background-and-reopen locking applies whenever a timeout is set (it is skipped only for Never).
- The lock is a full-screen password overlay, not a sign-out, so the session and its first-party cookies survive and unlocking is a single password step. The locked state is remembered on the device so a reload keeps the vault locked until the password is entered.
- Unlocking uses the same re-authentication step as the masked-field reveal (see `files.md`): a dedicated endpoint re-checks the signed-in user’s password. It deliberately does not affect the login lockout counters, since it confirms an already-signed-in user, and it records an audit entry for each success or failure.
- Not built in this bundle and still open (separate go-ahead needed): document sharing, multi-person profiles, and application-level encryption at rest (a deferred accepted risk).

Admin Console (Phase 2, implemented; upgraded Build 12)

The original two-tab admin panel was replaced by a full-screen Admin console at `/admin`. Admins reach it from a top-right “Admin” button on the home header (and the existing Settings entry). The console renders full width on desktop (not the phone-width app frame) with a persistent left sidebar; on smaller screens the sidebar collapses into a slide-over menu. An “Exit to app” control returns the admin to the normal app view.

Roles

- Two privilege levels: Admin (`isAdmin`) and Super Admin (`isSuperAdmin`). A super admin is also treated as an admin everywhere.
- `admin@lockondocs.com` is seeded as the super admin.
- Every admin API resolves the caller’s role from the database on each request (session flags are treated as a UI convenience only), and returns 403 for non-admins. Super-admin-only actions (role changes) return 403 for ordinary admins.
- Deleted or suspended accounts lose admin access immediately.

Dashboard

- Overview cards: total users (with admin count), total documents, total folders and total storage used. A date filter (Today, Last 7 days, Last 30 days, All time, or a custom calendar range) recomputes the “new in range” figures.
- Security widget: locked accounts, suspended accounts, failed logins in range, and deleted accounts.

- Cards drill down into the Users section pre-filtered to the matching set (for example the storage card opens Users sorted by storage, the locked card opens the locked accounts).
- Top users by storage list.

Users

- Searchable, sortable, paginated list of accounts (search by name or email; filter by all/admins/locked/suspended/deleted; sort by joined date, name or storage). CSV export respects the active filters.
- Each row has a “View” button that opens a user drawer showing the account summary and recent activity, with security actions: adjust storage limit, unlock, suspend or reinstate, and send a password reset link. Super admins cannot be suspended and an admin cannot suspend their own account.
- Deliberately no capability for an admin to open or browse another user’s documents: per-user isolation is preserved.
- **Multi-select delete (super admin only, Build 29).** Super admins see a checkbox on each row and a select-all checkbox in the header, plus a “Delete selected (N)” button. This is for clearing out test accounts in bulk. Deleting is permanent: it removes each selected account together with every document and every stored file (original and thumbnail) belonging to it, and records an `admin.user_deleted` audit entry per account before deletion. Super admin rows cannot be selected (their checkboxes are disabled), which also protects the signed-in super admin’s own account; the server independently refuses to delete the caller or any super admin and reports them as skipped. A confirmation dialog is shown before anything is deleted. The whole feature is hidden for ordinary admins.

Admin Management (super admin only)

- Hidden entirely unless the signed-in user is a super admin.
- Lists current admins and super admins, and a “Create admin” dialog searches the full user list to promote a user to Admin or Super Admin, or step an admin back down. The last remaining super admin cannot be removed.

Audit

- Full audit log with action filter, free-text search (detail or user email) and date range, plus CSV export.

Emails (Build 29)

- A log of the emails the app has sent: welcome and verification mails, password reset links, and the branded expiry reminder emails. Each row shows the recipient, the type, the subject, a short truncated preview of the body, the send status, and the date and time.
- Filterable by free-text search (recipient or subject), by type, by status, and by date range, with CSV export that respects the active filters. Newest first, paginated.
- **Status meaning:** “sent” means the mail provider accepted the message for delivery; “failed” means the provider rejected it (the error is recorded and shown). This is send-acceptance, not a mailbox delivery confirmation. Confirming actual inbox delivery (delivered, opened, bounced) would require wiring up the mail provider’s delivery webhooks, which is a possible future add-on and is noted, not built.
- Visible to all admins (not restricted to super admins). Records are written best-effort by the email helper on every send path, so a logging failure never blocks the email itself.

Backups (rebuilt in Build 20)

- Live operational status, not static text. The generic informational cards were removed. The screen now shows two status cards driven by real job data: “Code backup to GitHub” (weekly) and “Storage verification” (daily). Each card shows the latest run as a success or failed pill with its timestamp, a short summary line, detail chips (commit, branch and file count for the code push; document count, total size and user count for storage), a short recent-runs history list, the schedule, and a Refresh button. A clean empty state shows before a job has run.
- Data source: two scheduled jobs record their outcome to a `BackupLog` table. The weekly job pushes the application source to the customer GitHub repository (RichardDowman/lockondocs, main branch). The daily job is a read-only storage verification that confirms every stored document is accounted for in durable cloud storage (document count, total bytes, distinct users); it is a verification and inventory snapshot, not a physical copy into a second bucket.
- Endpoints live under `/api/admin` (stats, users, users/[id], audit, backups) and all verify the admin role server-side. A separate write-only `/api/backups/ingest` route lets the scheduled jobs record a result; it is authenticated with a shared Bearer secret (`BACKUP_INGEST_SECRET`), needs no admin session, and cannot read app data.

Auth Hardening (related, Phase 2)

- Password policy: minimum 8 characters, including at least one letter and one number. Enforced on signup and on password reset, and shown as a hint on the register form.
- Forgot password: `/forgot-password` emails a time-limited reset link (1 hour). The reset page verifies the token, applies the policy, and clears any logout.
- Email verification: a soft, non-blocking verification link (24 hours) is emailed on signup; `/verify-email` confirms it. Verification is not enforced at login.
- Account logout: 5 failed login attempts lock the account for 15 minutes.

Phase 3 Considerations

- GoodBarber auth pass-through: if GoodBarber provides authentication tokens, Settings should detect and use those rather than a separate login.
- Session management inside the iframe: handle session expiry gracefully and avoid full-page redirects that break the iframe. Note the live app deliberately opens the vault first-party for cookie and camera reliability.
- Deep linking: Settings may need to be reachable via a direct URL for GoodBarber navigation.

Technical Notes

Database

- User fields include: id, name, email, password hash, isAdmin, isSuperAdmin, storageUsed, storageLimit, emailVerified, failedLoginAttempts, lockedUntil, suspendedAt, timestamps, deletedAt.
- Suspension uses a dedicated `suspendedAt` timestamp (separate from the logout fields). A suspended user is blocked at login with a clear message; reinstating clears `suspendedAt`.
- Account deletion is a real delete: it removes the user’s S3 files (best effort), writes an audit entry, then deletes the account and cascades related records. It is not a soft-delete-with-grace-period.

Audit Log

- A best-effort `recordAudit` helper writes entries for folder update/delete, document move/delete, signup, admin actions, data export and account deletion, capturing client IP where available. Audit failures never block the main request.

Security

- Password reset and account deletion require verification (token or password).
- Admin actions are server-side gated on the `isAdmin` flag.

Dependencies

- Authentication system (login, session, `isAdmin` flag)
- Database schema (users, audit log)
- Cloud storage API (for storage usage and file deletion)